

Contoso - Corporate Procurement Policy & Playbook

Document ID: AC-PROC-POL-2024-001 **Version:** 3.2 **Effective Date:** January 1, 2024 **Last Reviewed:** December 15, 2023 **Owner:** Vice-President, Procurement & Strategic Sourcing **Classification:** Internal - Confidential

1. Purpose & Scope

This policy establishes the procurement and contract management standards for Contoso and its subsidiaries (collectively, "Contoso"). It applies to all agreements for goods, services, technology, consulting, and outsourced operations entered into by Contoso personnel, regardless of business unit or geographic location.

All employees involved in vendor selection, contract negotiation, or purchase authorization must comply with this policy. Non-compliance may result in disciplinary action, including termination.

2. Approval Authority & Thresholds

2.1 Contract Value-Based Approval Matrix

Contract Annual Value	Approval Authority	Additional Requirements
< \$25,000	Department Manager	Standard PO process; no legal review required
\$25,000 - \$49,999	Senior Manager	Procurement team notification; template contract required
\$50,000 - \$249,999	Director	Legal review required; competitive bid (min. 3 vendors)
\$250,000 - \$499,999	Vice-President	Legal review + compliance review; RFP required
\$500,000 - \$999,999	Senior Vice-President	Full legal, compliance, and finance review; Board committee notification
\$1,000,000 - \$4,999,999	Executive Vice-President / CFO	Full review suite; Board Audit & Finance Committee approval
>= \$5,000,000	CEO / Board of Directors	Full review suite; Board resolution required

2.2 Special Approval Requirements

- Sole-source contracts > \$100,000:** Require VP approval plus written justification and Procurement Director sign-off.
- Contracts with related parties:** Require CFO approval regardless of value.
- Contracts involving personal data:** Require Privacy Office review regardless of value.
- Enterprise safety-critical contracts:** Require VP Operations and VP Safety sign-off regardless of value.
- Cross-border contracts:** Require Tax department review for any value above \$50,000.

2.3 Amendment & Change Order Thresholds

Change Order Value (Cumulative)	Approval Authority
< 10% of original value or < \$25,000	Original approver

10-25% of original value	One level above original approver
> 25% of original value	Requires new contract process

3. Mandatory Contract Clauses

Every Contoso contract with a value exceeding \$25,000 **must** include the following clauses. Contracts using approved templates include these clauses by default. Any deviation requires Legal department approval.

3.1 Indemnification

The vendor must indemnify Contoso against all claims, damages, losses, and expenses arising from:

- Vendor's breach of the agreement
- Vendor's negligence or willful misconduct
- Infringement of third-party intellectual property rights
- Vendor's violation of applicable laws

Minimum standard: Mutual indemnification with carve-outs for IP infringement, data breach, and gross negligence/willful misconduct (vendor bears full indemnification for these).

3.2 Limitation of Liability

- **General cap:** The greater of (a) 2x the annual contract value, or (b) \$1,000,000.
- **Uncapped carve-outs:** Indemnification for IP infringement, data breach, confidentiality breach, gross negligence, and willful misconduct.
- **Consequential damages:** Contoso's standard position is mutual exclusion of consequential damages, with carve-outs for data breach and confidentiality breach.
- **PROHIBITED:** Any clause imposing unlimited liability on Contoso, or any cap on vendor liability below 1x annual contract value.

3.3 Intellectual Property Ownership

- **Work product:** All deliverables created specifically for Contoso are "work made for hire" and owned by Contoso.
- **Pre-existing IP:** Vendor retains ownership but grants Contoso a perpetual, irrevocable, royalty-free license.
- **Joint IP:** Must be explicitly defined; default position is Contoso ownership.
- **Source code escrow:** Required for any custom software development exceeding \$250,000.

3.4 Confidentiality

- **Term:** Obligations survive for 5 years after agreement termination (or indefinitely for trade secrets).
- **Scope:** Covers all non-public information exchanged between parties.
- **Return/destruction:** Vendor must return or certify destruction of all confidential information within 30 days of termination.
- **Permitted disclosures:** Only to vendor employees/subcontractors with need-to-know, bound by equivalent obligations.
- **Multi-language requirement:** For contracts involving customer-facing services in New York State, confidentiality provisions must address materials in all required languages.

3.5 Termination

- **Termination for convenience:** Contoso must retain the right to terminate for convenience with 30-90 days' written notice (based on contract value and complexity).

- **Termination for cause:** Standard 30-day cure period for material breach (except for data breach or safety incidents, which allow immediate termination).
- **Transition assistance:** Vendor must provide reasonable transition assistance for a minimum of 90 days following termination of contracts > \$250,000.
- **Wind-down payments:** Only amounts for services actually rendered through termination date, plus pre-approved wind-down costs.

3.6 Force Majeure

- **Standard events:** Natural disasters, pandemics, government actions, war, terrorism, strikes, transportation disruptions.
- **Industry-specific events:** Infrastructure disruptions, regulatory authority directives, facility closures.
- **Notice requirement:** Affected party must provide notice within 5 business days.
- **Duration cap:** Either party may terminate if force majeure continues for more than 90 consecutive days.
- **Mitigation:** Affected party must use commercially reasonable efforts to mitigate impact.

3.7 Data Protection & Privacy

- **Data Privacy Regulation compliance:** Required for all contracts involving personal information of domestic residents.
- **Regional Privacy Regulation:** Contracts involving local residents' personal information must comply with applicable data privacy regulations.
- **Cross-border transfers:** Personal information of domestic residents must be stored and processed domestically unless explicitly approved by the Privacy Office with appropriate safeguards.
- **Breach notification:** Vendor must notify Contoso within 24 hours of discovering a data breach.

3.8 Governing Law & Dispute Resolution

- **Default governing law:** Laws of the State of New York and federal laws of the domestic jurisdiction applicable therein.
- **Dispute resolution:** Negotiation -> Mediation (AAA rules) -> Arbitration (AAA rules, the designated forum) -> Litigation (the competent state court).
- **Language:** Contracts must be available in required languages where required by local jurisdiction requirements.

4. Prohibited Terms & Conditions

The following terms are **strictly prohibited** and must be rejected during negotiation. No exceptions without written approval from the General Counsel.

Prohibited Term	Reason	Exception Process
Unlimited liability for Contoso	Unacceptable financial exposure	General Counsel only
Auto-renewal periods exceeding 3 years	Operational and financial lock-in risk	EVP/CFO approval required
Exclusive dealing arrangements	Anti-competitive; limits operational flexibility	General Counsel + CEO approval
Unilateral price increase rights	Budget unpredictability	Director Procurement + CFO

Vendor right to assign without consent	Counterparty risk	General Counsel only
Waiver of jury trial	Not applicable/enforceable domestically	N/A - reject outright
Non-compete clauses binding Contoso	Limits operational flexibility	General Counsel only
Automatic IP assignment to vendor	Loss of Contoso's intellectual property	General Counsel only
Limitation period shorter than statutory	Reduces Contoso's rights	General Counsel only
Mandatory foreign jurisdiction	Enforceability and cost concerns	General Counsel approval

5. Payment Terms Standards

5.1 Standard Payment Terms by Contract Value

Contract Annual Value	Standard Payment Terms	Exceptions
< \$50,000	Net 30 from invoice receipt	None
\$50,000 - \$499,999	Net 45 from invoice receipt	Net 30 with 2% early payment discount
\$500,000 - \$4,999,999	Net 60 from invoice receipt	Net 45 with 1.5% early payment discount
>= \$5,000,000	Net 90 from invoice receipt	Net 60 with 1% early payment discount

5.2 Payment Conditions

- **Milestone-based payments:** Required for all project-based contracts > \$250,000. No more than 25% of total value payable in advance.
- **Holdback:** 10% holdback on deliverable-based contracts until final acceptance.
- **Currency:** Payments in domestic Dollars (USD) unless foreign currency is specifically justified and approved by Treasury.
- **Late payment interest:** Standard rate is prime rate + 2%, compounding monthly.
- **Invoice requirements:** Must include PO number, detailed description of services, Sales Tax registration numbers, and supporting documentation for expenses.

5.3 Prohibited Payment Arrangements

- Payment terms shorter than Net 30 without VP Finance approval.
- Advance payments exceeding 25% of total contract value.
- Payment in cryptocurrency or non-standard instruments.
- Payment to jurisdictions on FATF grey/black lists without enhanced due diligence.

6. Insurance Requirements

6.1 Requirements by Contract Type

Contract Type	Commercial General Liability	Professional Liability (E&O)	Cyber/Tech E&O	Workers' Compensation	Automobile
General Services	\$2M per occurrence / \$5M aggregate	-	-	Statutory	\$2M (if applicable)
Professional/Consulting	\$2M per occurrence / \$5M aggregate	\$5M per claim / \$10M aggregate	-	Statutory	\$2M (if applicable)
Technology/SaaS	\$2M per occurrence / \$5M aggregate	\$5M per claim / \$10M aggregate	\$10M per claim	Statutory	-
Construction/Facilities	\$5M per occurrence / \$10M aggregate	\$5M per claim	-	Statutory	\$5M
Enterprise Services (On-site)	\$10M per occurrence / \$25M aggregate	\$10M per claim	-	Statutory	\$5M
Data Processing	\$2M per occurrence / \$5M aggregate	\$5M per claim	\$15M per claim	Statutory	-

6.2 General Insurance Requirements

- Contoso must be named as an additional insured on all CGL policies.
- Policies must provide 30 days' written notice prior to cancellation or material change.
- Certificates of insurance must be provided prior to contract commencement and annually thereafter.
- Vendors must maintain insurance for the duration of the contract plus 2 years for claims-made policies.
- Deductibles exceeding \$100,000 require Procurement Director approval.
- Insurers must be rated A- (Excellent) or better by AM Best.

7. Cybersecurity Requirements for Technology Vendors

7.1 Mandatory Security Standards

All technology vendors with access to Contoso systems or data must comply with:

- **SOC 2 Type II certification** (or equivalent) - current report required before contract execution.
- **ISO 27001 certification** - required for vendors processing or storing Contoso data.
- **Data residency:** All Contoso data must be stored within the domestic jurisdiction unless explicitly approved by CISO. Processing may occur in the US with appropriate safeguards.

- **Encryption:** AES-256 at rest; TLS 1.2+ in transit. No exceptions.
- **Access controls:** Multi-factor authentication (MFA) required for all access to Contoso systems or data.
- **Vulnerability management:** Vendors must remediate critical vulnerabilities within 72 hours and high-severity within 30 days.
- **Penetration testing:** Annual third-party penetration test required; results shared with Contoso.
- **Incident response:** Vendor must notify Contoso within 24 hours of any security incident. Full incident report within 72 hours.

7.2 Data Classification & Handling

Data Classification	Storage Requirements	Access Requirements	Breach Notification
Public	Standard	Standard	72 hours
Internal	Encrypted at rest	Role-based access	48 hours
Confidential	Encrypted, domestic-only	MFA + role-based + audit logging	24 hours
Restricted (PII, Financial)	Encrypted, domestic-only, isolated	MFA + privileged access management + real-time monitoring	Immediate (within 4 hours)

7.3 Right to Audit

Contoso retains the right to:

- Conduct security assessments or audits with 30 days' notice.
- Require remediation of identified deficiencies within agreed timelines.
- Terminate the agreement immediately in the event of a material security breach.

8. Tax Compliance Requirements

8.1 domestic Tax Requirements

- Vendors must provide valid Sales Tax registration numbers and Sales Tax registration (for locally-based services).
- Invoices must comply with the tax authority requirements for input tax credits.
- Non-resident vendors must comply with withholding tax requirements under the applicable tax laws.
- Vendors performing services in multiple states must properly allocate and charge applicable state/regional taxes.

8.2 Cross-Border Considerations

- Contracts with US vendors exceeding \$50,000 require Tax department review for treaty benefit application.
- International contracts must address permanent establishment risk.
- Transfer pricing documentation required for intercompany agreements.
- Withholding tax obligations must be clearly assigned (vendor responsibility to claim treaty benefits).
- Vendors must provide applicable tax forms (e.g., W-8BEN-E for US treaty benefits).

8.3 Enterprise-Specific Tax Considerations

- Service surcharges and industry-specific levies must be separately identified.
- Ground handling services may have different tax treatment by jurisdiction.

- International region-specific services must consider bilateral service agreement implications.

9. Standard Review SLAs

9.1 Contract Review Turnaround Times

Contract Type	Value Range	Standard Review SLA	Expedited Review SLA
Standard services (template)	< \$100,000	5 business days	2 business days
Standard services (custom)	< \$100,000	10 business days	5 business days
Complex services	\$100,000 - \$500,000	15 business days	7 business days
Strategic/high-value	> \$500,000	20 business days	10 business days
Amendments/renewals	Any	5 business days	2 business days
NDA's (template)	Any	3 business days	1 business day
NDA's (custom)	Any	7 business days	3 business days

9.2 Escalation for Delayed Reviews

Delay	Escalation Level
2 business days past SLA	Procurement Director
5 business days past SLA	VP Procurement
10 business days past SLA	General Counsel / EVP

9.3 Expedited Review Criteria

Expedited review may be requested when:

- Business-critical deadline within 10 business days.
- Safety or regulatory compliance requirement.
- Board or executive directive.
- Revenue-generating opportunity at risk.

Requests must be approved by the requesting VP and acknowledged by the Legal department.

10. Vendor Classification & Due Diligence

10.1 Vendor Risk Tiers

Tier	Criteria	Due Diligence Requirements
Tier 1 - Critical	Annual spend > \$1M or operational dependency	Full due diligence, annual review, business continuity plan required
Tier 2 - Significant	Annual spend \$250K-\$1M	Standard due diligence, biennial review

Tier 3 - Standard	Annual spend \$50K-\$250K	Basic due diligence, triennial review
Tier 4 - Low	Annual spend < \$50K	Simplified due diligence at onboarding

10.2 Due Diligence Checklist

- Financial statements (last 3 years) - Tier 1 and 2
- Credit report - All tiers
- References (minimum 3) - Tier 1, 2, and 3
- Sanctions/denied parties screening - All tiers
- Beneficial ownership verification - Tier 1 and 2
- Insurance certificates - All tiers (per Section 6)
- Security certifications - Technology vendors (per Section 7)
- ESG/sustainability assessment - Tier 1

11. Contract Lifecycle Management

11.1 Key Milestones

Milestone	Timeline	Responsibility
Contract expiry notification	180 days before expiry	Procurement
Renewal assessment	150 days before expiry	Business owner + Procurement
Renewal negotiation	120 days before expiry	Procurement + Legal
Renewal execution	60 days before expiry	All approvers per Section 2
Post-execution filing	Within 5 business days	Procurement (Document Management System/SharePoint)

11.2 Record Retention

- Executed contracts: 7 years after termination.
- Supporting documents (RFPs, evaluations): 5 years after contract termination.
- Financial records: Per tax authority requirements (minimum 6 years).

12. Policy Exceptions

Any exception to this policy must be:

1. Requested in writing with business justification.
2. Reviewed by the Procurement Director.
3. Approved by the appropriate authority per the matrix below.
4. Documented in the contract file with the exception approval attached.

Exception Type	Approval Authority
----------------	--------------------

Approval threshold deviation	One level above standard approver
Missing mandatory clause	General Counsel
Prohibited term acceptance	General Counsel + CFO
Payment terms deviation	VP Finance
Insurance requirement reduction	VP Risk Management
Cybersecurity requirement waiver	CISO + General Counsel

This policy is reviewed annually by the Procurement Policy Committee. Questions should be directed to procurement.policy@contoso.com.

Last approved by: Marie-Helene Dubois, SVP Procurement & Strategic Sourcing - December 15, 2023